

WHEN AI ATTACKS

AI THREAT ASSESSMENT WORKBOOK

Digital Content #1 — Weaponized Trust: Prompt Injection & Social Engineering

Purpose: Use this workbook to assess whether a prompt injection or AI social engineering attack has occurred, is currently underway, or whether your organization carries the exposure that would allow one. If an incident is active or suspected, go directly to Section 03 — Root Cause.

01 Exposure Check

Answer Yes / No / Unknown for your environment. Every Unknown is a gap. Three or more Unknowns = this is your next tabletop agenda.

Question	Yes	No	Unknown / Gap	Notes
Do you have a current inventory of every AI system that can read external content and take action?	☐	☐	☐	
Has a security architecture review been completed for each AI agent with financial or access workflow permissions?	☐	☐	☐	
Does your logging config capture the full context window at execution — not just the output?	☐	☐	☐	
Is there a named human authority on record for every action an AI agent takes?	☐	☐	☐	
Has your red team run adversarial prompt injection against production AI systems in the last 90 days?	☐	☐	☐	
Does your IR playbook include a documented procedure for an AI agent manipulation event?	☐	☐	☐	
Can you revoke an AI agent's permissions in real time without taking down the business workflow?	☐	☐	☐	
Are your phishing simulations testing AI-generated spear phishing — not just template-based attacks?	☐	☐	☐	

02 Accountability — Who Owns What

Function	Owner (Name / Role)	Last Reviewed	Gap
AI system inventory and registry			☐
Security architecture review for AI deployments			☐
AI agent permission governance (what each agent can and cannot do)			☐
Prompt injection red team / adversarial testing			☐

Function	Owner (Name / Role)	Last Reviewed	Gap
AI incident detection and containment			☐
Context window logging and forensic preservation			☐
Board reporting on AI risk posture			☐

03 Root Cause — If an Incident Is Active or Suspected

Work through these four questions with your IR team. Capture specifics — not "TBD."

	Question	What to Capture
01	What external content did the AI system process immediately before the anomalous action?	Name the document, email, or data source. Preserve the original.
02	What was the AI permitted to do — and did the action fall within those boundaries?	Pull the agent's permission scope. If undocumented, that is your first finding.
03	What does the context window show at time of execution?	If logging did not capture it, document that gap and reconstruct from available artifacts.
04	Who had authority to approve what the agent did — and was that approval obtained?	Trace the action to a named human decision. If the answer is "no one," that is accountability gap #1.

04 Five Questions to Bring to Your Next Executive Meeting

	Question	Your Answer / Status
01	Name every AI system in your environment that can act on external input without human approval.	
02	When an AI agent acts, what record exists of whose authority it acted under?	
03	Has your red team run adversarial prompt injection against production AI systems?	
04	If an agent were manipulated today — who executes containment, and how?	
05	Does your board understand an AI agent can be manipulated without touching your perimeter?	

05 Directives — Assign an Owner and a Date

	Audience	Directive	Owner	Done By
01	CISO	Reclassify every AI system as a trust boundary. Retroactive architecture review if it reads external content and acts.		
02	CISO	Constrain agent permissions by function. Human approval required for any action touching money, access, or external comms.		
03	CISO	Build an AI agent registry. Every action traces to a named human authority.		
04	CISO	Update phishing simulations to include AI-generated spear phishing mirroring internal tone.		
05	IR	Capture four artifacts at every AI incident: input, context window, action taken, output. Fix logging now.		
06	IR	Baseline normal AI behavior for all workflows touching financials, access, or external comms.		
07	IR	Add AI agents to your kill chain. If not in your detection model, they are not in your coverage.		
08	IR	Test containment: revoke permissions in real time, roll back actions, isolate workflow. Run the tabletop.		
09	IR	Apply Diamond Model to AI investigations: what was the agent authorized to do, and how did attacker content reach its context window?		

Assessment prepared by Matsui LLC · matsuihq.ai